

Guía Metodológica Detallada

Encuesta COSO-Ciber · Kit de Diagnóstico v2025.1

Indicadores y Métricas de Ciberseguridad en el Marco COSO — Aplicación a España

"Una encuesta sin metodología es como un mapa sin escala: puede ser decorativa, pero nadie debería navegar con ella."

1. Fundamentos Epistemológicos

Esta encuesta se inscribe en un **paradigma post-positivista mixto**, combinando:

- Enfoque cuantitativo: escalas de Likert (1–5), ítems de selección única y múltiple, indicadores de cobertura, puntuaciones de madurez y cálculo del Índice Global de Madurez (IGM).
- Enfoque cualitativo: preguntas abiertas del Bloque X para capturar narrativas, conocimiento tácito y experiencia situada imposibles de cuantificar con ítems cerrados.

El referente primario de medición es la norma **ISO/IEC 27004:2016** (*Information security management — Monitoring, measurement, analysis and evaluation*). El diseño adopta la metodología **GQM (Goal-Question-Metric)** de Basili (1994): los indicadores derivan de objetivos y preguntas de investigación formulados explícitamente.

2. Objetivos de la Investigación

2.1 Objetivo General (OG)

Evaluar el estado de adopción de indicadores y métricas de ciberseguridad alineados con el marco COSO en organizaciones que operan en España, identificando brechas, tendencias y oportunidades de mejora con perspectiva comparada internacional (UE, EE.UU., LATAM).

2.2 Objetivos Específicos (OE)

Cód.	Objetivo Específico	Bloque(s)	Marco COSO
OE-1	Caracterizar gobernanza y cultura ciber en el consejo	I, VII	ERM C-I / CGF P-8
OE-2	Evaluar la integración del ciberriesgo en la estrategia	II	ERM C-II
OE-3	Medir la implementación de indicadores de desempeño ciber	III	ERM C-III
OE-4	Identificar preparación ante riesgos emergentes (IA, PQC)	IV	ERM P-6 / P-15
OE-5	Analizar el estado de cumplimiento regulatorio (NIS2, ENS, DORA)	V	IC Cumplimiento
OE-6	Evaluar la madurez del ciclo de revisión del control ciber	VI	ERM C-IV
OE-7	Caracterizar la calidad del reporte de ciberriesgo al consejo	VII	ERM C-V
OE-8	Estimar el ROI y la capacidad de cuantificación financiera	VIII	ERM + FAIR
OE-9	Posicionar organizaciones en el IGM	VIII, IX	Todos
OE-10	Identificar barreras, habilitadores y prioridades 2026	IX, X	Todos

3. Diseño Muestral

3.1 Población Objetivo

Organizaciones que operen en España con:

- Más de 50 empleados, **O**
- Sujetas a obligaciones de NIS2, ENS (cualquier categoría) o DORA

Encuestados en roles de decisión sobre ciberseguridad, riesgos, cumplimiento, TI o gobierno corporativo.

Criterios de inclusión:

- Actividad principal o sede en España
- Encuestado con responsabilidades directas sobre el ámbito de la encuesta
- Acceso a información sobre las prácticas de ciberseguridad de su organización

Criterios de exclusión:

- Consultores sin acceso a datos internos del cliente
- Estudiantes sin posición organizacional relevante
- Microempresas (<10 empleados) sin obligaciones NIS2

3.2 Estrategia de Muestreo

Muestreo estratificado no proporcional con cuotas por:

1. Sector de actividad (NIS2: sectores de alta criticidad vs. sectores importantes)
2. Tamaño organizacional (4 estratos: pequeña, mediana, grande, corporación)
3. Tipo de entidad (pública vs. privada)
4. Perfil del encuestado (consejo/alta dirección · CISO/CRO · técnico)

3.3 Tamaño Muestral Mínimo

Para error muestral $\pm 5\%$, nivel de confianza 95% y varianza máxima:

$$n = (Z^2 \times p \times q) / e^2 = (1,96^2 \times 0,5 \times 0,5) / 0,05^2 = 384 \text{ respuestas válidas mínimas}$$

Objetivo práctico: 500–600 respuestas válidas para análisis por subgrupos (mínimo 30 respuestas por celda de cruce sector $\times$ tamaño).

3.4 Canales de Distribución Recomendados

Canal	Ventajas	Sesgo potencial
ISMS Forum, ISACA Spain, (ISC) ² Spain	Acceso a practicantes cualificados	Sobre-representación de organizaciones maduras
INCIBE / CCN-CERT (canal oficial)	Alta legitimidad; alcance nacional	Sesgo hacia sector público
LinkedIn (segmentación por cargo y sector)	Alto alcance, bajo coste	Sobre-representación de CISOs visibles
Eventos sectoriales (ENISE, RootedCON, SecAdmin)	Respuestas de alta calidad	Alcance limitado; early adopters
Panel online (Prolific, Dynata)	Control demográfico	Menor profundidad de respuesta

4. Instrumento de Medición — Decisiones de Diseño

4.1 Estructura por Bloques

Bloque	Denominación	Componente COSO	Preguntas	Tipo principal
0	Perfil organizacional	Variables de control	7	Opción única/múltiple
I	Gobernanza y Cultura	ERM C-I / CGF P-8	8	Escala + opción única
II	Estrategia y Apetito de Riesgo	ERM C-II	6	Opción múltiple
III	Desempeño — Métricas Operativas	ERM C-III	11	Escala + opción única
IV	Riesgos Emergentes	ERM P-6 + P-15	4	Opción múltiple
V	Marco Regulatorio	IC Control / ERM P-20	4	Opción única
VI	Revisión, Mejora y Monitoreo	ERM C-IV	5	Escala + múltiple
VII	Información y Reporte	ERM C-V	4	Opción única/múltiple
VIII	ROI y Madurez Estratégica	ERM + FAIR	3	Múltiple + escala
IX	Perspectiva Comparada	Benchmarking	3	Única + múltiple
X	Reflexión Final	Cualitativo	4	Respuesta abierta
TOTAL			~59	Mixto

4.2 Escalas de Medición

Escala de Madurez COSO-Ciber (1-5) — Basada en CMMI v2.0

Nivel	Etiqueta	Descripción operacional
1	Inexistente	Sin proceso; respuesta reactiva ante eventos
2	Inicial	Prácticas informales, personas-dependientes
3	Definido	Procesos documentados; formación establecida
4	Gestionado	Métricas activas; mejora continua; reporte al consejo
5	Optimizado	Mejora proactiva; benchmarking; anticipación de riesgos emergentes

4.3 Indicadores de Alerta Temprana (⚡ IAT)

Las **14 preguntas IAT** representan los controles COSO con mayor impacto en la reducción del riesgo:

P-1.1 (supervisión consejo) · P-1.2 (competencia ciber consejo) · P-1.4 (línea reporte CISO) · P-1.6 (cultura ciber) · P-2.1 (integración estratégica) · P-2.3 (apetito de riesgo) · P-3.1 (registro de riesgos) · P-3.2 (gestión vulnerabilidades) · P-3.3 (Time-to-Patch) · P-3.4 (TtE como KRI) · P-3.5 (MTTD/MTTR) · P-3.6 (IAM/MFA) · P-3.9 (resiliencia y BC) · P-7.1 (calidad reporte consejo)

Una respuesta de nivel 1 o 2 en cualquier IAT activa revisión prioritaria en el plan de mejora.

5. Índice Global de Madurez (IGM)

5.1 Pesos por Componente COSO

Componente COSO	Bloque(s)	Peso IGM	Justificación
Gobernanza y Cultura (C-I)	I	25%	Condición necesaria de todos los demás componentes
Estrategia y Apetito de Riesgo (C-II)	II	20%	Diferenciador de madurez estratégica
Desempeño / Métricas Operativas (C-III)	III	30%	Mayor densidad de indicadores medibles e impacto directo
Revisión y Mejora (C-IV)	VI	10%	Derivado de C-III; condición de mejora continua
Información, Comunicación y Reporte (C-V)	VII	15%	Cierre del ciclo de gobierno

5.2 Fórmula del IGM

$$IGM = (P_GOB \times 0,25) + (P_EST \times 0,20) + (P_DES \times 0,30) + (P_REV \times 0,10) + (P_INF \times 0,15)$$

Donde cada P_XXX es la puntuación media del componente (escala 1–5) calculada mediante la tabla de conversión incluida en la Plantilla Excel (Documento e).

5.3 Interpretación del IGM

Rango IGM	Clasificación	Recomendación General
1,0–1,9	Crítico 	Intervención inmediata en controles básicos; prioridad en las 14 IATs
2,0–2,9	Emergente 	Plan de mejora estructurado a 12 meses; formalización de procesos clave
3,0–3,9	Establecido 	Optimización de métricas; integración en ERM; mejora del reporte
4,0–4,5	Avanzado 	Cuantificación financiera del riesgo (FAIR/CRQ); benchmarking activo
4,6–5,0	Líder 	Referente sectorial; contribución a marcos e iniciativas sectoriales

6. Análisis Estadístico

6.1 Análisis Descriptivo

- Variables cuantitativas: media, mediana, desviación típica, cuartiles, distribución de frecuencias
- Variables categóricas: tablas de frecuencia, gráficos de barras/Sankey, distribución porcentual
- IGM: histograma, percentiles, boxplot por sector/tamaño/perfil

6.2 Análisis Inferencial

Técnica	Propósito	Variables involucradas
ANOVA / Kruskal-Wallis	Comparar IGM medio entre sectores, tamaños y perfiles	IGM vs. sector, tamaño, perfil
Correlación de Spearman	Relaciones entre componentes del IGM	P_GOB, P_EST, P_DES, etc.
Análisis de conglomerados (k-means)	Tipologías organizacionales de madurez	Todos los ítems cuantitativos
Regresión logística ordinal	Predictores del nivel de madurez	Variables Bloque 0 como predictores
Análisis de correspondencias	Asociaciones entre sector y prácticas	Variables nominales

6.3 Análisis Cualitativo (Bloque X)

- Análisis de contenido temático de las respuestas abiertas
- Codificación axial siguiendo las 5 categorías del marco COSO
- Análisis de co-ocurrencias para identificar patrones semánticos (NVivo o Atlas.ti)
- Word cloud ponderado por frecuencia

6.4 Validez y Fiabilidad

Tipo	Método	Umbral objetivo
Validez de contenido	Panel de expertos (7+: 3 CISO, 2 académicos, 1 regulador, 1 auditor)	Índice Lawshe $\geq 0,62$
Validez de constructo	Análisis Factorial Confirmatorio (AFC)	CFI $> 0,95$; RMSEA $< 0,06$; SRMR $< 0,08$
Fiabilidad interna	Alfa de Cronbach por bloque	$\alpha > 0,70$ para escalas multi-ítem
Estabilidad	Test-retest (n=30, 15 días)	$r > 0,75$

7. Procedimiento de Aplicación

7.1 Fases del Trabajo de Campo

Fase	Actividad	Duración
0	Validación por panel de expertos	4 semanas
1	Piloto (30 organizaciones)	3 semanas
2	Refinamiento del instrumento	1 semana
3	Distribución masiva (canales múltiples)	6–8 semanas
4	Seguimiento y recordatorios	Durante F3
5	Cierre y depuración de datos	1 semana
6	Análisis estadístico y construcción IGM	3 semanas
7	Redacción del informe de resultados	3 semanas
8	Difusión y presentación de resultados	2 semanas
Total		~23 semanas

7.2 Herramienta de Distribución

Recomendada: LimeSurvey (versión autoalojada — control total de datos, cumplimiento RGPD).

Alternativa: Google Forms (proyectos académicos con recursos limitados).

7.3 Gestión de Sesgos

Sesgo	Descripción	Medida de Control
Deseabilidad social	Responder "lo que debería ser"	Formulación sin juicio de valor; anonimidad prominente
Autoselección	Responden organizaciones más interesadas	Comparar perfil de respondentes con el universo; ajuste ponderado
Información asimétrica	El encuestado no conoce todos los datos	"Si no dispone de datos exactos, proporcione estimación"
Varianza de método común	Un solo encuestado responde predictor y resultado	Separar encuestados por rol; triangular con datos objetivos
Marco temporal	Eventos recientes sesgan la percepción	Ventana temporal explícita en preguntas ("en los últimos 12 meses")

8. Consideraciones Éticas

- Anonimato garantizado: datos individuales no publicados ni compartidos con terceros
- Consentimiento informado: declaración explícita al inicio del instrumento
- Proporcionalidad: 45–60 minutos justificados por el valor del diagnóstico obtenido
- Reciprocidad: los participantes reciben el informe de resultados agregado del sector
- Cumplimiento RGPD: conforme al Reglamento UE 2016/679 y la LOPDGDD (LO 3/2018)
- No discriminación: los resultados no se utilizan para sancionar ni excluir organizaciones individuales

9. Referencias Metodológicas

- COSO ERM (2017). Enterprise Risk Management — Integrating with Strategy and Performance.
- COSO IC (2013). Internal Control — Integrated Framework.
- COSO / PwC (2026). Corporate Governance: Guiding Principles for Board Oversight.
- ISO/IEC 27004:2016. Information security management — Monitoring, measurement, analysis and evaluation.
- Basili, V. R., Caldiera, G., & Rombach, H. D. (1994). The Goal Question Metric Approach. Encyclopedia of Software Engineering.
- ENISA (2025). NIS Investments 2025 — Main Report.
- NIST IR 8286r1 (2025). Integrating Cybersecurity and Enterprise Risk Management (ERM).
- FAIR Institute (2025). State of Cyber Risk Management Report.
- INCIBE (2026). Balance de Ciberseguridad 2025.
- CCN-CERT (2025). Ciberamenazas y Tendencias — Edición 2025.